Mattermost Cross Guard Threat Model

Security analysis of Cross Guard's cross-domain relay architecture

Introduction

Cross Guard operates as a Cross Domain Solution (CDS), bridging two or more Mattermost instances across security domain boundaries using NATS as the transport. This page documents the trust boundaries, the data that crosses them, and the threats and mitigations at each layer.

Intended audience: security reviewers, accreditors, and administrators evaluating Cross Guard for deployment in classified or sensitive environments.

System Architecture and Trust Zones

```
Zone 1: Mattermost Server A         Zone 3: NATS Bus          Zone 5: Mattermost S
+----------------------------+     +------------------+     +---------------------
|  Users, Teams, Channels    |     |                  |     |  Users, Teams, Chann
|  Mattermost API            |     |  NATS Server     |     |  Mattermost API
|  +----------------------+  |     |  (may be shared  |     |  +------------------
|  | Zone 2: Cross Guard  |  |     |   or dedicated)  |     |  | Zone 4: Cross Gua
|  | Plugin (Outbound)    |--|---->|  Subject-based   |---->|--| Plugin (Inbound)
|  | hooks.go, nats.go    |  |     |  pub/sub routing  |     |  | inbound.go
|  +----------------------+  |     +------------------+     |  +------------------
+----------------------------+                               +--------------------
```

Zone	Description	Trust Level	Controlled By
Zone 1: Mattermost Server A	Source Mattermost instance. Users, teams, channels, posts. Authenticated via Mattermost session management.	Trusted	Server A admin
Zone 2: Cross Guard	Plugin code running inside Server A. Hooks into post lifecycle events (`MessageHasBeenPosted` ,	Trusted (same	Plugin code + Server A

Zone	Description	Trust Level	Controlled By
Plugin (Outbound)	`MessageHasBeenUpdated`, `MessageHasBeenDeleted`, reaction hooks in `hooks.go`). Serializes to NATS envelope, publishes via `nats.go:publishToOutbound()`.	process as Mattermost)	admin config
Zone 3: NATS Bus	External message broker. Receives published messages, delivers to subscribers. Can be shared or dedicated. May be in a separate network segment.	Semi-trusted (transport security only)	NATS admin (may be separate from MM admin)
Zone 4: Cross Guard Plugin (Inbound)	Plugin code running inside Server B. Subscribes to NATS, deserializes envelopes (`inbound.go:handleInboundMessage()`), resolves teams/channels/users, creates local posts.	Trusted (same process as Mattermost)	Plugin code + Server B admin config
Zone 5: Mattermost Server B	Destination Mattermost instance. Receives relayed messages as locally-created posts.	Trusted	Server B admin

Data Crossing the Domain Boundary

The following data structures from `server/model/` transit the NATS bus between trust zones. Understanding exactly what crosses the boundary is critical for CDS evaluation.

Envelope (`model/message.go:Envelope`)

The envelope is a single-layer structure with the payload embedded directly (not as a serialized string). Messages may be serialized as JSON or XML depending on the outbound connection's `message_format` setting. Inbound format is auto-detected by `model.DetectFormat()`.

`type`	Message type constant (e.g., `crossguard_post`)
`timestamp`	RFC 3339 UTC timestamp

`post_message`	Post or update payload (present when type is `crossguard_post` or `crossguard_update`)
`delete_message`	Delete payload (present when type is `crossguard_delete`)
`reaction_message`	Reaction payload (present when type is `crossguard_reaction_add` or `crossguard_reaction_remove`)
`test_message`	Test payload (present when type is `crossguard_test`)

PostMessage Payload (`crossguard_post`, `crossguard_update`)

Field	Source	User-Controlled?	Used On Receive For
`post_id`	`post.Id` (26-char Mattermost ID)	No	Post mapping (KV store key)
`root_id`	`post.RootId`	No	Thread parent resolution
`channel_id`	`post.ChannelId`	No	Not used directly (name-based routing)
`channel_name`	`channel.Name`	Indirectly (admin-set)	**Routing: `GetChannelByName()`**
`team_id`	`channel.TeamId`	No	Not used directly
`team_name`	`team.Name`	Indirectly (admin-set)	**Routing: `GetTeamByName()` or rewrite lookup**
`user_id`	`post.UserId`	No	Not used on receive
`username`	`user.Username`	Yes (users choose usernames)	**User resolution: `resolveInboundUser()`**
`message`	`post.Message`	**Yes** (full post content)	Post body text
`create_at`	`post.CreateAt`	No	Not used on receive

DeleteMessage Payload (`crossguard_delete`)

Fields: `post_id` , `channel_id` , `channel_name` , `team_id` , `team_name`

ReactionMessage Payload (`crossguard_reaction_add` , `crossguard_reaction_remove`)

All PostMessage fields except `message` , `root_id` , `create_at` ; adds `emoji_name` .

Data Intentionally Excluded from Relay

> **Good security hygiene**
> The following data is intentionally excluded from the relay envelope: post properties (`post.Props` , except the internal `crossguard_relayed` flag), user metadata (email, profile image, custom fields), channel purpose/header, hashtags, pinned status, edit history, and interactive message elements (buttons, menus). File attachments (`post.FileIds`) are not included in the envelope but can be transferred separately via NATS JetStream Object Store when `file_transfer_enabled` is true on the connection. File transfer is disabled by default and supports allow/deny type filtering and size limits.

Threat Analysis (STRIDE)

Each threat is identified by a unique ID, categorized by STRIDE, and assessed for severity. Code references point to the specific source files where the behavior occurs.

Spoofing

T-SPOOF-1: Username Impersonation via Username Lookup

Severity	MEDIUM
Description	When `UsernameLookup` is enabled (default: `true`), `resolveInboundUser()` in `sync_user.go` looks up a local user by the `username` field from the inbound message. If a match is found, the relayed post is created under that real local user's ID. An attacker controlling the remote Mattermost instance (or with NATS write access) can forge messages that appear to come from any local user whose username they know.

Code Path	`inbound.go` calls `resolveInboundUser()`, which calls `p.API.GetUserByUsername(username)` in `sync_user.go`. If found and not a sync user, returns the real user ID.
Mitigation	1. Disable `UsernameLookup` in plugin settings to force all inbound messages through synthetic sync users (e.g., `alice.relay-from-a`). Sync users are visually distinguishable by their `LastName` field showing `(via connName)`. 2. Restrict NATS server network access to only authorized Mattermost servers using IPsec, firewall rules, or network segmentation. Configure NATS ACLs so only authorized Mattermost server clients can publish to `crossguard.*` subjects.
Residual Risk	When `UsernameLookup` is enabled, impersonation remains possible from a compromised but network-authorized Mattermost server. The combination of network-level restrictions and NATS ACLs significantly reduces the attack surface compared to an open NATS bus.

T-SPOOF-2: NATS Message Injection (No Per-Message Authentication)

Severity	MEDIUM
Description	The NATS envelope (`model/message.go:Envelope`) contains no cryptographic signature, HMAC, or message authentication code. Any entity with publish access to the NATS subject can inject arbitrary messages (in either JSON or XML format) that the inbound handler will process as legitimate.
Code Path	`inbound.go` calls `model.DetectFormat(msg.Data)` followed by `model.Unmarshal()` with no signature verification. The deserialized envelope is dispatched directly to handlers.
Mitigation	1. TLS encryption (`nats.go`, min TLS 1.2) protects against passive eavesdropping. NATS authentication (token or credentials) restricts who can connect. 2. Restrict NATS server network access to only authorized Mattermost servers using IPsec, firewall rules, or network segmentation. Configure NATS ACLs so only authorized Mattermost server clients can publish to `crossguard.*` subjects.

Residual Risk	A compromised but network-authorized Mattermost server with valid NATS credentials can still inject messages. No end-to-end integrity verification exists, but the combination of network-level restrictions and NATS ACLs significantly limits the attack surface.

Tampering

T-TAMP-1: Unauthorized Post Edit Propagation

Severity	MEDIUM
Description	`handleInboundUpdate()` in `inbound.go` looks up a local post by remote post ID mapping and replaces its `Message` field. There is no verification that the update came from the original author or that the remote user had edit permissions.
Code Path	`inbound.go` retrieves mapping, sets `existing.Message = postMsg.Message`, calls `UpdatePost()`.
Mitigation	Post mapping keys (`pm-{connName}-{remotePostId}`) use connection-scoped namespaces, limiting edits to the connection that created the original post. The remote Mattermost server enforces its own edit permissions before relaying.
Residual Risk	If NATS credentials are compromised, fabricated update messages can modify any previously relayed post.

T-TAMP-2: Unauthorized Post Deletion

Severity	MEDIUM
Description	`handleInboundDelete()` in `inbound.go` deletes a local post based solely on the remote post ID in the NATS message. No author or permission verification.
Code Path	`inbound.go` retrieves mapping, calls `DeletePost(localPostID)`.
Mitigation	Same connection-scoped namespace as edits. The deleting flag mechanism (`SetDeletingFlag` / `ClearDeletingFlag`) prevents delete loops but does not authenticate the delete request.
Residual Risk	Same as T-TAMP-1.

T-TAMP-3: Post Mapping Overwrite

Severity	LOW
Description	`SetPostMapping()` in `inbound.go` stores `connName:remotePostId -> localPostId`. If an attacker sends a new post with a previously-used remote post ID, the mapping is overwritten, causing future edits/deletes to target the wrong local post.
Mitigation	Post IDs are 26-character random strings (Mattermost `NewId()`), making collision unlikely without intentional targeting. Connection-scoped namespacing limits blast radius.

Repudiation

T-REPUD-1: No Audit Trail for Relayed Actions

Severity	MEDIUM
Description	Relayed posts, edits, deletes, and reactions are created via the Mattermost Plugin API. While Mattermost logs post creation, there is no Cross Guard-specific audit log linking a local action back to the specific NATS message, remote server, or remote user that triggered it.
Mitigation	Plugin logs contain connection name, remote post IDs, and usernames at DEBUG/WARN level. Team init/teardown actions post bot announcements to `#town-square` with the acting user's name. The `crossguard_relayed` post property marks all inbound posts.
Residual Risk	Forensic reconstruction requires correlating logs across both Mattermost instances and the NATS server.

Information Disclosure

T-INFO-1: Message Content Visible to NATS Server

Severity	MEDIUM (in classified environments)
Description	TLS encrypts data in transit between plugin and NATS server, but the NATS server itself processes messages in cleartext. A compromised or malicious NATS server operator can read all relayed message content.
Mitigation	1. Use a dedicated, locally-administered NATS server. Enable TLS with mutual certificate authentication (`client_cert` / `client_key` in `nats.go`). For

CDS deployments, the NATS server should be within a controlled enclave.

2. Restrict NATS server network access to only authorized Mattermost servers using IPsec, firewall rules, or network segmentation. Configure NATS ACLs so only authorized Mattermost server clients can subscribe to `crossguard.*` subjects.

Residual Risk	No application-layer encryption. The NATS server still sees plaintext payloads, but network-level restrictions and ACLs limit exposure to only authorized infrastructure.

T-INFO-2: Team/Channel Topology Leakage

Severity	LOW
Description	NATS envelopes contain `team_name` and `channel_name` from the source server. An entity with NATS subscribe access learns the team and channel structure of the sending server.
Mitigation	Use dedicated NATS subjects per connection pair. Restrict NATS ACLs.

T-INFO-3: Status Endpoint Data Exposure

Severity	LOW
Description	`GET /api/v1/teams/{team_id}/status` and `GET /api/v1/channels/{channel_id}/status` are accessible to any team/channel member (not just admins). These reveal connection names, directions, and remote team name rewrites.
Mitigation	Global status (`GET /api/v1/status`) is restricted to System Admins. Connection credentials (tokens, passwords, cert paths) are redacted from all status responses.

T-INFO-4: NATS Credentials in Plugin Configuration

Severity	LOW
Description	NATS tokens and passwords are stored as plaintext strings in the plugin settings JSON (`configuration.go`). Any System Admin can view them in the System Console.

Mitigation	Only System Admins can access plugin configuration. Credentials are redacted in status API responses.

Denial of Service

T-DOS-1: Inbound Message Flood

Severity	MEDIUM
Description	The inbound handler uses a semaphore of 256 concurrent goroutines (`plugin.go` `relaySem`). An attacker flooding the NATS subject can fill the semaphore, causing legitimate messages to be dropped with "Relay semaphore full, dropping inbound message" warnings.
Code Path	`inbound.go` , semaphore channel check with `default:` drop.
Mitigation	The semaphore prevents unbounded resource consumption. NATS server rate limiting can be configured externally. Connection authentication limits who can publish.
Residual Risk	No per-connection or per-subject rate limiting within the plugin itself.

T-DOS-2: Outbound Retry Amplification

Severity	LOW
Description	`publishToOutbound()` in `nats.go` retries failed publishes 3 times with exponential backoff (500ms, 1s, 2s). If NATS is unreachable, each outbound message blocks a goroutine for up to ~3.5 seconds.
Mitigation	Context cancellation (`ctx.Done()`) allows graceful shutdown. Messages are dropped (not queued) after retry exhaustion.

Elevation of Privilege

T-PRIV-1: Connection Management by Non-Admins

Severity	MEDIUM
Description	By default (`RestrictToSystemAdmins=false`), Team Admins can link/unlink NATS connections to their teams, and Channel Admins can manage channel

	connections. A compromised or rogue Team Admin could enable relay on channels without broader organizational approval.
Code Path	`command.go` (`isTeamAdminOrSystemAdmin`) checks `RestrictToSystemAdmins`.
Mitigation	Enable `RestrictToSystemAdmins` setting to lock all connection management to System Admins only. Inbound connections require explicit Accept via admin prompts before messages flow.
Residual Risk	With the setting disabled, the blast radius is limited to the Team Admin's own team.

T-PRIV-2: Sync User Auto-Membership

Severity	MEDIUM
Description	`ensureMembership()` in `sync_user.go` automatically adds sync users (and real users when username lookup is enabled) to teams and channels as messages arrive. This bypasses normal Mattermost invitation/join workflows.
Code Path	`sync_user.go` calls `ensureMembership(user.Id, teamID, channelID)`, which calls `CreateTeamMember` and `AddChannelMember`.
Mitigation	Only affects channels/teams that have been explicitly linked to an inbound connection by an admin. The `system_user` role assigned to sync users provides no admin privileges.

Relay Loop Prevention

Loop prevention is critical for CDS operation. Cross Guard uses multiple independent mechanisms to ensure a relayed message is never re-relayed back to its source.

Primary: `crossguard_relayed` Property

- Inbound posts are created with `post.AddProp("crossguard_relayed", true)` in `inbound.go`
- Outbound hooks check `post.GetProp("crossguard_relayed") != nil` in `hooks.go` and skip if present

- This prevents a relayed post from being re-relayed back to the source

Secondary: Bot User Filtering

- All outbound hooks check `post.UserId == p.botUserID` in `hooks.go` and skip bot posts
- Bot announcements (init/teardown messages) never relay

Tertiary: Sync User Filtering for Reactions

- `hooks.go` checks `user.Position == "crossguard-sync"` to prevent sync user reactions from relaying back

Delete-Specific: Deleting Flag

- `inbound.go` sets `SetDeletingFlag(localPostID)` before calling `DeletePost`
- `hooks.go` checks `IsDeletingFlagSet(post.Id)` in `MessageHasBeenDeleted` hook
- If set, the delete is not re-relayed, preventing infinite delete loops
- Flag is cleared after deletion completes

NATS Transport Security

TLS Configuration

- Minimum TLS 1.2 enforced (`tls.VersionTLS12`)
- Optional mutual TLS: client certificate + key pair
- Optional CA certificate for server verification
- Both `client_cert` and `client_key` must be provided together (validated)

Authentication Methods

Method	Configuration	Description
`none`	No additional fields	No NATS authentication

Method	Configuration	Description
`token`	`token` field	NATS token-based auth
`credentials`	`username` + `password`	Username/password auth

Connection Resilience

- Persistent connections with unlimited reconnects (`natsMaxReconnects = -1`)
- 2-second reconnect wait
- Disconnect/reconnect event logging

Recommendations by Deployment Sensitivity

Deployment	TLS	Auth	Mutual TLS	Dedicated NATS	NATS ACLs
Development	Optional	Optional	No	No	No
Production (standard)	Required	Token or credentials	Recommended	Recommended	Recommended
CDS (classified)	Required	Credentials	Required	Required	Required

Inbound Connection Acceptance Flow

The prompt-based acceptance workflow prevents unauthorized inbound relay. No messages flow until an admin explicitly accepts the connection at both the team and channel level.

```
Inbound message arrives
        |
        v
  Team linked? ----No----> Post Accept/Block prompt to #town-square
        |                          |
       Yes              Admin clicks Accept
        |                          |
```

```
        v                          v
Channel linked? --No--> Post Accept/Block prompt to channel
        |                          |
       Yes              Admin clicks Accept
        |                          |
        v                          v
Resolve user, create post      Link channel, process message
```

1. Inbound message arrives for an unlinked team
2. `handleUnlinkedInbound()` posts interactive prompt to `#town-square` with Accept/Block buttons
3. Team Admin or System Admin clicks Accept (calls `POST /api/v1/prompt/accept`)
4. Handler verifies `isTeamAdminOrSystemAdmin()` permission
5. Connection is linked to team, prompt deleted
6. Same flow repeats at channel level
7. Blocked prompts can be cleared with `/crossguard reset-prompt`

Deployment Recommendations for CDS Environments

> **Hardened Configuration Checklist**
> The following settings are recommended for Cross Guard deployments in classified or sensitive environments.

1. **Enable `RestrictToSystemAdmins`**: Lock all connection management to System Admins.
2. **Disable `UsernameLookup`**: Force all inbound messages through sync users to prevent impersonation.
3. **Enable TLS with mutual authentication**: Use client certificates on all NATS connections.
4. **Dedicated NATS server**: Do not share the NATS server with other applications.
5. **NATS ACLs**: Restrict publish/subscribe permissions per subject per client.

6. **Separate subjects per direction**: Use different NATS subjects for each relay direction (e.g., `crossguard.a-to-b` and `crossguard.b-to-a`) to prevent echo.

7. **Network segmentation**: Place NATS server in a controlled network segment between the two Mattermost instances.

8. **Monitor plugin logs**: Watch for "Relay semaphore full", "Unknown inbound message type", and failed resolve warnings as indicators of anomalous activity.

9. **Review sync users periodically**: Audit users with `Position="crossguard-sync"` to detect unexpected user creation.

10. **Use `crossguard.` subject prefix enforcement**: All subjects must start with `crossguard.` (validated in `configuration.go`), preventing accidental subscription to unrelated NATS traffic.

Threat Summary Matrix

ID	Threat	Category	Severity	Mitigated?	Control
T-SPOOF-1	Username impersonation	Spoofing	MEDIUM	Partial	Disable `UsernameLookup` + NATS network/ACL restrictions
T-SPOOF-2	NATS message injection	Spoofing	MEDIUM	Partial	TLS + NATS auth + network/ACL restrictions
T-TAMP-1	Unauthorized edit propagation	Tampering	MEDIUM	Partial	Connection-scoped mapping
T-TAMP-2	Unauthorized delete propagation	Tampering	MEDIUM	Partial	Connection-scoped mapping
T-TAMP-3	Post mapping overwrite	Tampering	LOW	By design	Random 26-char IDs

ID	Threat	Category	Severity	Mitigated?	Control
T-REPUD-1	No audit trail	Repudiation	MEDIUM	Partial	Plugin logs + bot announcements
T-INFO-1	NATS sees cleartext	Info Disclosure	MEDIUM	Partial	Dedicated NATS + mTLS + network/ACL restrictions
T-INFO-2	Topology leakage	Info Disclosure	LOW	Partial	Dedicated subjects + ACLs
T-INFO-3	Status data to members	Info Disclosure	LOW	By design	Credentials redacted
T-INFO-4	Config credentials	Info Disclosure	LOW	By design	System Admin only
T-DOS-1	Inbound message flood	DoS	MEDIUM	Partial	Semaphore (256) + NATS rate limiting
T-DOS-2	Outbound retry amplification	DoS	LOW	By design	3 retries, context cancellation
T-PRIV-1	Non-admin connection mgmt	Privilege	MEDIUM	Config option	Enable `RestrictToSystemAdmins`
T-PRIV-2	Sync user auto-membership	Privilege	MEDIUM	By design	Limited to linked channels